DATA SECURITY ANALYSIS



AYUSH KUMAR JHA

16.02.2025

Section 1:
Data Governance

Strategic Data Security Policies

IT Staff should perform a data classification annually, or when there are notable business or technology changes.
Benefits: • Helps identify and categorize data based on sensitivity, ensuring proper handling and protection. • Reduces the risk of data breaches by applying appropriate security controls. • Enhanced operational efficiency by prioritizing security efforts on the most critical data
IT Staff should perform an application and critical system classification annually, or when there are notable business or technology changes.
Benefits: • Ensures that mission-critical applications and systems receive the necessary security measures. • Helps IT team allocate resources efficiently for risk mitigation. • Enhances resilience by identifying potential vulnerabilities in key systems
IT Staff should perform a regulatory assessment annually, or when there are notable business or technology changes.
Benefits: • Ensures continuous compliance with evolving industry regulations and legal requirements. • Helps mitigate legal and financial risks associated with non-compliance • Identified gaps in security policies and enabled proactive remediation. • Building trust with customers and stakeholders by demonstrating a commitment to data security.

Data Classification

Confidential: Highly sensitive data that, if exposed, could cause financial, legal, or reputational harm. Access is strictly restricted
Internal: Information intended for internal use only. Unauthorized disclosure could impact operations but is not as confidential data
Public: Information that can be freely shared without any security concerns.

Categorize each dataset into one of the three data types

Dataset	Data Type
Employee profile data	CONFIDENTIAL
Customer profile data	CONFIDENTIAL
Company email	INTERNAL
Repository of previously published blogs	PUBLIC
Internal employee newsletters	INTERNAL
Technology engineering diagrams	CONFIDENTIAL
Intellectual property	CONFIDENTIAL

Data Regulations

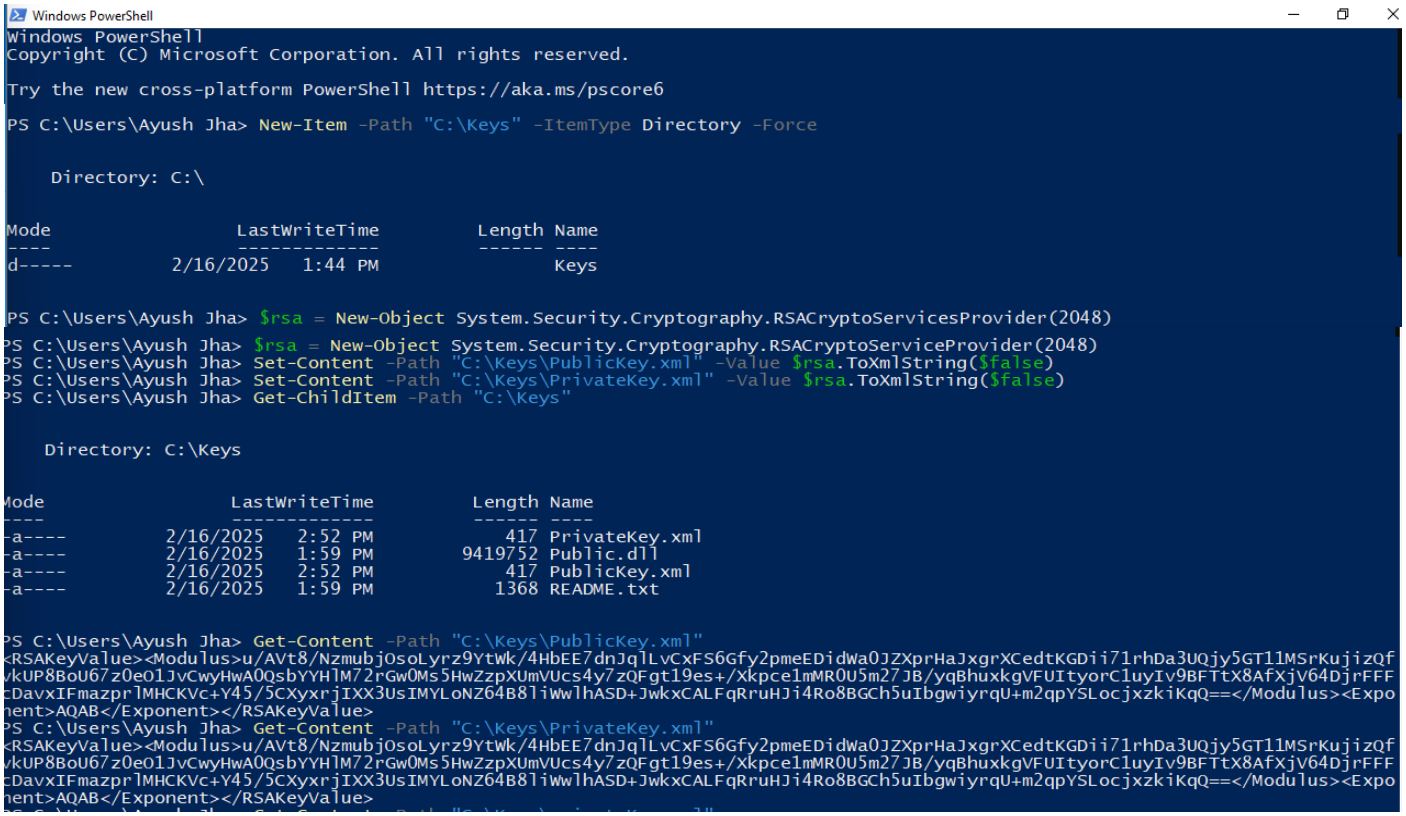
Confidential	**General Data Protection Regulation(GDPR):** Protects EU citizens' data and requires stringent security measures. Confidential data includes sensitive customer and employee information, financial records, and proprietary business data. These regulations enforce strict data protection measures to prevent breaches, and unauthorized access, and ensure compliance with industry standards
Internal	**National Institute of Standards and Technology(NIST) Framework:** Provides cybersecurity best practices for internal systems and operational security. While not as sensitive as confidential data, internal data may contain business strategies, internal communications, and operational processes. Regulations like NIST guide to ensure integrity, security, and compliance with corporate governance standards
Public	**Freedom of Information Act(FOIA):** Ensures transparency for publicly available data. Public data includes marketing materials press releases, and blog posts. While generally not subject to strict security regulations, laws like FOIA and consumer protection laws ensure that public data is accurate, legally compliant, and does not mislead

Regulatory Compliance

DATA ENCRYPTION POLICY: All confidential and sensitive data, including customer financial information and employee records, must be encrypted both at rest and in transit using industry-standard encryption protocols. Ensures compliance with GDPR by protecting data from unauthorized access and breaches
ACCESS CONTROL POLICY: Access to confidential and internal data must follow the principle of least privilege Role-based access control must be implemented, and all access requests must be reviewed and approved by authorized personnel. Multi-factor authentication must be enforced for all systems storing or processing sensitive data. Aligns with NIST by minimizing the risk of unauthorized access to sensitive information
DATA RETENTION AND DISPOSAL POLICY: Confidential and internal data must be retained only for the period required by regulatory and business needs. Secure data disposal methods, including cryptographic wining or physical destruction, must be used when data is no longer needed. Data retention policies must comply with regulatory requirements such as GDPR's "right to be forgotten" and PCI-DSS data storage limitations.
SECURITY INCIDENT AND BREACH NOTIFICATION POLICY: Any security incident involving unauthorized access, disclosure, or breach of confidential or internal data must be reported immediately to the security team. Breach notification procedures must align with regulatory requirements. Incident response teams must be prepared to mitigate and document security breaches.
THIRD-PARTY VENDOR SECURITY POLICY: All third-party vendors handling Jfin Payments' confidential or internal data must comply with security and privacy standards equivalent to those required by Jfin Payments. Vendors must undergo security assessments and sign data protection agreements to ensure compliance with applicable regulations
SECURITY AWARENESS AND TRAINING POLICY: All employees handling confidential or internal data must complete mandatory cybersecurity training at least once a year. Training topics must phishing awareness, secure data handling, access control measures, and regulatory compliance obligations

Section 2:
Data Confidentiality

Securing Disks



Section 3:
Data Integrity

File Integrity Verification

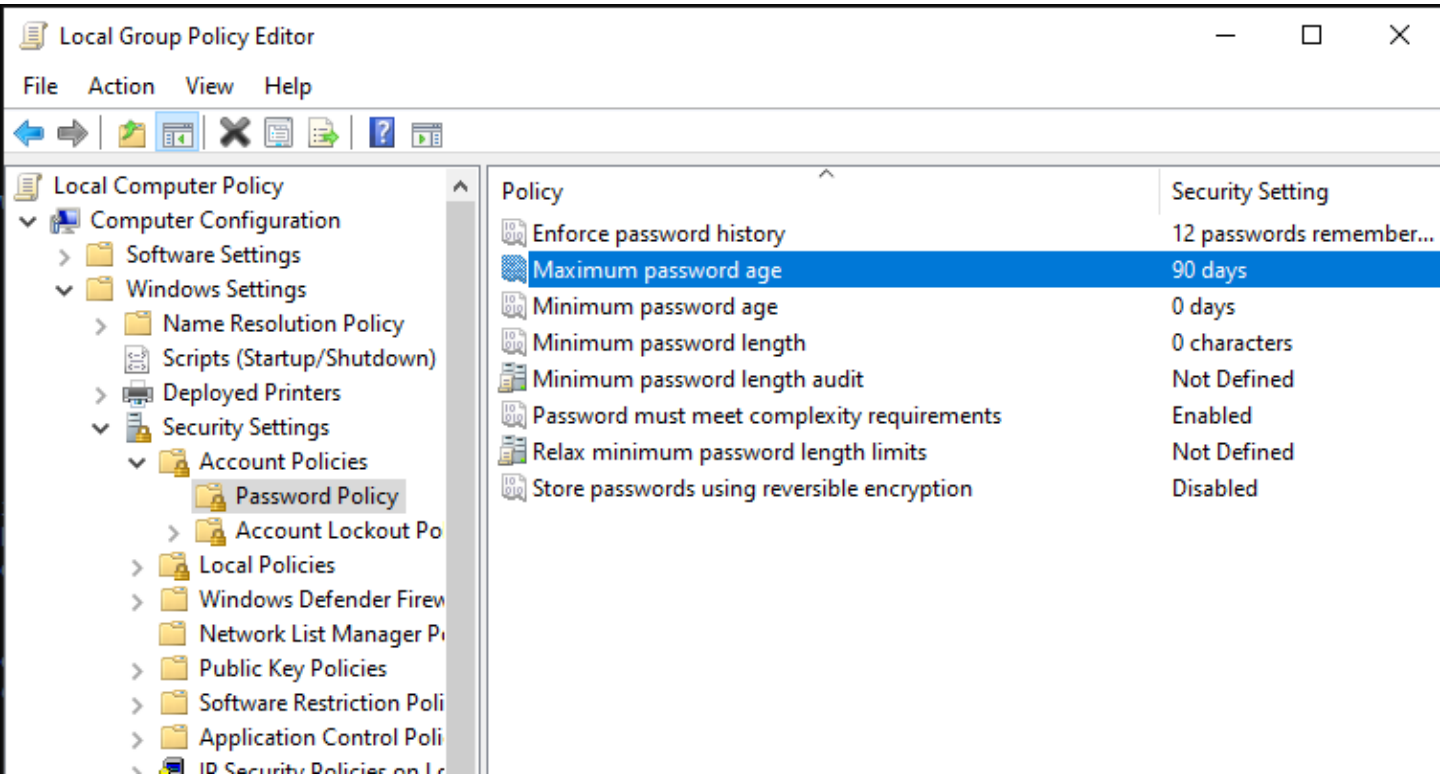
Download public.dll from dll-files.com and verify Hash.

Version 14.0.0.130
The original public.dll hash: f7761cd21b7461fd126ecbac1fa7e516138349fb

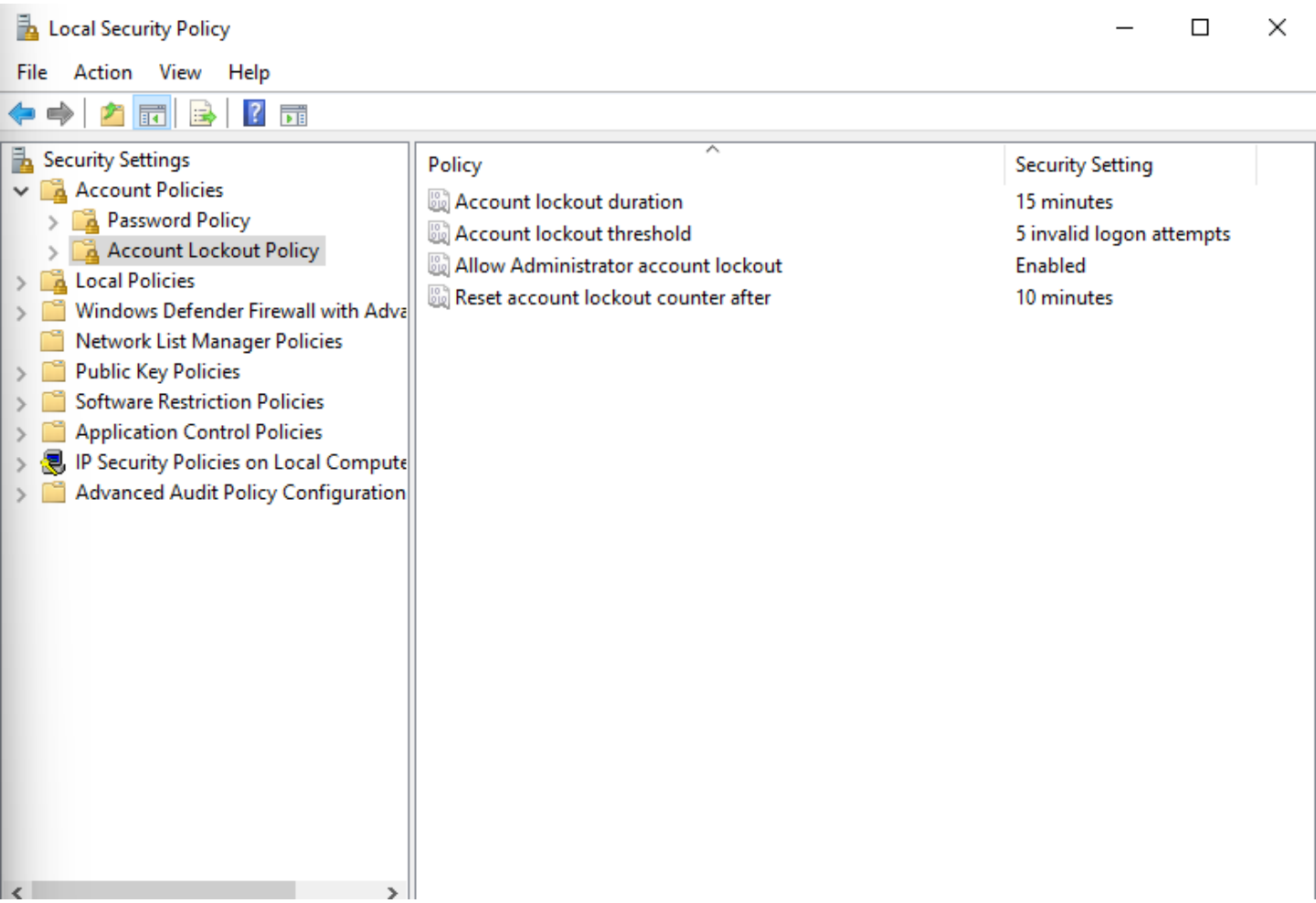
Since the files doest not match they may have been altered possibly due to reasons such as corruption during download or malware infection and must not be trusted or used further



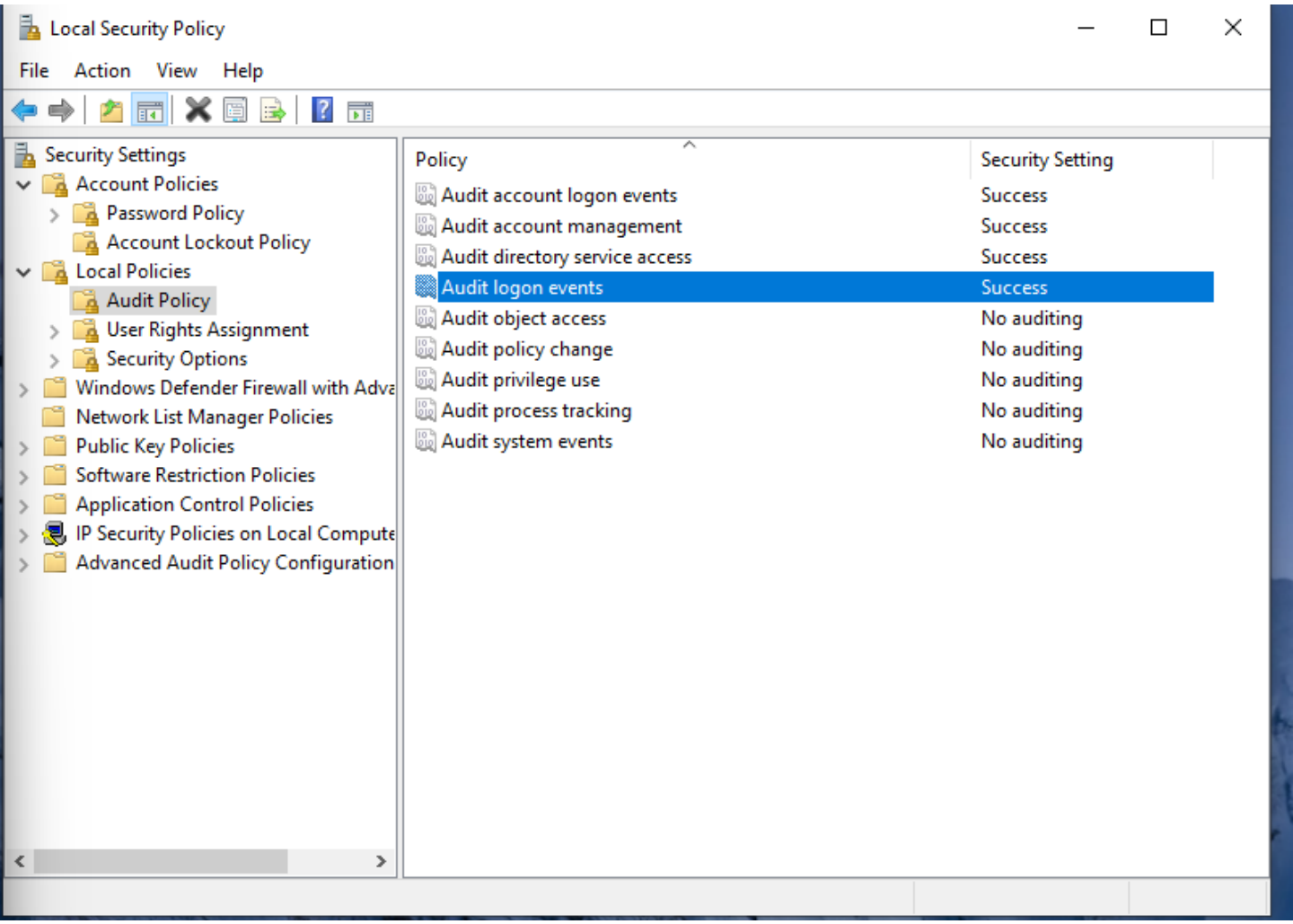
Auditing Security Settings



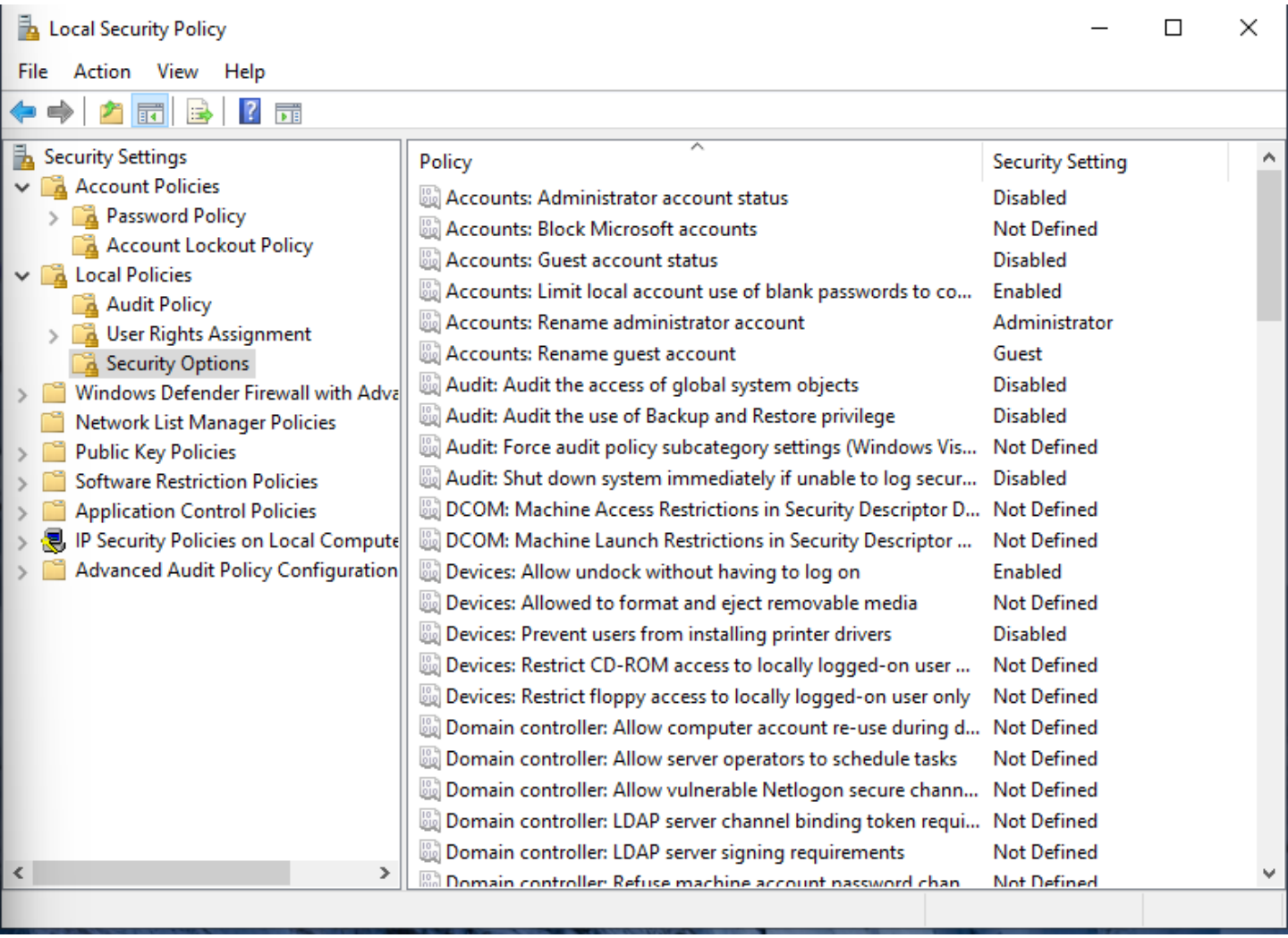
Auditing Security Settings



Auditing Security Settings



Auditing Security Settings



Enhancing VM Security

1. STRENGTHEN PASSWORD POLICY
Set the minimum length of 12-16 characters. Enforce uppercase, lowercase, numbers, and special characters. Change the passwords every 90 days and prevent using the last 5 passwords. A strong password policy reduces the risk of brute-force attacks and unauthorized access by ensuring passwords are difficult to guess.
2. ENFORCE ACCOUNT LOCKOUT POLICY
Configuring account lockout setting by setting the lockout threshold to 5 failed login attempts and setting the duration for the lockout to 15 minutes and 30 minutes as reset counter. Prevents repeated brute-force attacks by temporarily locking accounts after multiple failed login attempts. This helps protect against credential-stuffing attacks
3. ENABLE ADVANCED AUDIT POLICY
This can be done by enabling logging for login/logon events by tracking all successful and failed attempts. Monitoring access to sensitive resources and mainly to critical files. Proper logging helps with forensic analysis and compliance with regulations by maintaining a record of security-related activities.
4. HARDEN SECURITY OPTIONS
This can be done by disabling unnecessary services and restricting remote login to specific IP addresses. Enabling Multi-Factor Authentication for admins' accounts and disabling legacy protocols can even help

Section 4:
Data Availability

Developing a Data Backup Strategy

Confidential Data	
Backup Frequency:	Real-time
Retention Period:	1 year
Confidential data includes highly sensitive information such as transactions, encryption keys, and personally identifiable information. Regulations like GDPR, and HIPAA require secure and frequent backups. Real-time backup ensure minimal data loss in case of cyber incidents. Retaining for at least 1 year ensures compliance with financial and legal auditing requirements	
Internal Data	
Backup Frequency:	Daily
Retention Period:	90 days
Internal data is important for operations but less critical than confidential data. Daily backups help mitigate accidental deletion or system failures. A 90-day retention aligns with best practices for business continuity while minimizing storage costs. Internal policies and frameworks recommend protecting business-critical data without excessive retention.	

Developing a Data Backup Strategy

Public Data	
Backup Frequency:	Weekly
Retention Period:	30 days
Public data is already accessible and does not contain sensitive information. Weekly backups are sufficient to restore in case of additional deletion or website failure. Retaining for 30 days ensures a balance between operational efficiency and storage management. This aligns with general IT best practices for non-critical data	

Creating a Backup

